Web Application Penetration Test Report

Report: 01/23

Target: **pingbreakers.com**

Assessment Type: External BlackBox Web Application Penetration Test

Prepared by: Kaburu Zeddie

Role: Penetration Tester

Organization: HackersForYou

Date: 15 October 2023

This report summarizes the results of a penetration test conducted against the PingBreakers web application and associated infrastructure.

Executive Summary

HackersForYou conducted an external web application penetration testing against the PingBreakers website: **https://pinbreakers.com**. The objective was to assess the security posture of the website, identify potential vulnerabilities that could lead to security risks, and provide valuable insights into the current state of security and enable the development of recommendations for enhancing the overall resilience of the web application.

The assessment was performed using a black-box testing approach, where no specific information or constraints were provided regarding the scope of the assessment. The objective was to evaluate the security of these platforms to identify potential vulnerabilities that could pose risks to the organization.

Testing Approach and Defenses:

The assessment employed a black-box testing approach, simulating an external attacker with no prior knowledge of the system. Noteworthy is the effectiveness of the implemented Web Application Firewall (WAF) and access control measures, which significantly impeded various attack vectors.

Summary of Findings:

These findings provide valuable insights into potential vulnerabilities and security gaps within the assessed system. Each finding should be carefully addressed to enhance the overall security posture.

ID	Vulnerability	Severity	Status
F01	Weak Password Policy	High	Confirmed
F02	Missing Security Headers	Medium	Confirmed
F03	Server Banner Disclosure	Low	Confirmed
F04	Incorrect Error Handling	Low	Confirmed
F05	/robots.txt Entry '/login.php'	Low	Confirmed

F06	Uncommon Header 'platform'	Low	Confirmed
F07	File Path Exposure via E-Tags	Low	Confirmed
F08	alt-svc Header	Informational	Confirmed
F09	Unpresent CGI Directories	Informational	Confirmed
F10	SSL Negotiation Issue	Informational	Confirmed

Finding F01: Weak password policy

The password policy could be strengthened to better protect user accounts from unauthorized access.

Finding F02: Missing Security Headers

- **X-Frame-Options Header Not Set**

Additional measures could be taken to guard against a specific type of attack known as clickjacking. Implement additional measures to safeguard against clickjacking attacks.

- **X-Content-Type-Options Header Not Set**

Some adjustments could be made to ensure that files are interpreted correctly, reducing the risk of certain types of attacks.

Ensure files are interpreted correctly to mitigate certain types of attacks.

- **Strict-Transport-Security Header Not Defined**

The Strict-Transport-Security HTTP header is not defined, potentially leaving the application vulnerable to certain types of attacks. Implement the recommended security header to strengthen the overall security posture.

Finding F03: Server Banner Disclosures

Some information about the server's software and version is being exposed, which could be a potential risk. It is recommended to Consider hiding specific server information to reduce potential risks.

Finding F04: Incorrect Error Handling

Server errors are revealing the server technologies. There's an opportunity to enhance how errors are handled to prevent potential vulnerabilities.

Finding F05: /robots.txt Entry '/login.php'

The Admin login page is mentioned in a file that could be easily discovered, potentially making it more accessible to unauthorized users. Review and possibly restrict access to and exposure of the admin login page to enhance security.

Finding F06: Uncommon Header 'platform'

There's a non-standard piece of information being provided that might give attackers insights into the hosting environment. Evaluate the necessity of the non-standard platform information and consider its removal.

Finding F07: File Path Exposure via E-Tags

There's a potential issue where the server could inadvertently reveal details about its internal file structure. Take steps to prevent inadvertent exposure of internal file system details.

Finding F08: alt-svc Header

There's an indication that the server supports a cutting-edge protocol, which might reveal more about its capabilities.Evaluate the necessity of revealing support for the next-generation protocol.

Finding F09: Unpresent CGI Directories

No immediate action required as no sensitive directories were identified.

Finding F10: SSL Negotiation Issue

A minor technical issue was encountered while establishing a secure connection. Investigate and resolve the SSL negotiation issue to ensure secure **connections.**

Risk Assessment:

The identified vulnerabilities, while encountered, were effectively mitigated by the existing security measures. As such, the overall risk of a successful exploit is medium. The security team's efforts in implementing and maintaining these measures are commendable.

Recommendations:

In order to fortify the website's security, we have identified several key areas for improvement. These include enhancing the password policy to better safeguard user accounts, evaluating the visibility of the admin login page, and addressing potential vulnerabilities in how errors are handled. Additionally, we recommend implementing certain security headers and protocols to further bolster defenses. While some of these recommendations involve technical adjustments, they collectively contribute to a more robust and resilient security posture and they will proactively mitigate potential risks and ensure the safety of our sensitive information.

Overall, the website and subdomain at ***http://lol.pingbreakers.com***, demonstrates a commendable level of security. The identified vulnerabilities are largely mitigated by robust security measures. Ongoing vigilance and regular audits will further enhance the organization's security posture.

Table of Contents

Include a detailed table of contents to help readers navigate the report.

Introduction **7**
Methodology **8**
Target Information **10**
Vulnerability Analysis and Findings **14**
Vulnerability Analysis process: 14
Findings: 20
Finding F01: Weak password policy 20
Finding F02: Missing Security Headers 21
1: X-Frame-options Header not set. 21
2: X-Content-Type-Options Header Not set 23
3: Strict-Transport-Security Header not defined 23
Finding F03: Server banners Disclosure 24
Finding F04: Incorrect error handling 26
Finding F05: /robots.txt Entry '/login.php' 27
Finding F06: Uncommon header ‘platform’ 30
Finding F07: File Path Exposure via E-Tags 31
Finding F08: alt-svc Header 31
Finding F09: Unpresent CGI Directories 32
Finding F10: SSL Negotiation failure: 33
Risk Assessment 33
Risk Classification and Scoring 35
Recommendations 37
Critical Recommendations: 38
High-Priority Recommendations: 38
Medium-Priority Recommendations: 38
Low-Priority Recommendations: 38
Conclusion **38**
Acknowledgments **40**
Contact Information **40**
Limitations: **40**

Introduction

This report provides a comprehensive overview of the recent penetration test conducted on the web infrastructure of ***https://pingbreakers.com*** . The objective of this assessment was to evaluate the security posture of the specified domains and identify potential vulnerabilities that could expose sensitive information or lead to unauthorized access.

Scope

The scope of this penetration test included a thorough examination of the web assets hosted on the ***pingbreakers.com*** domain, as well as its subdomains. The assessment focused on identifying vulnerabilities within the web application layer, specifically targeting potential flaws in input validation, session management, and authentication mechanisms. It is important to note that this test did not encompass an analysis of the underlying network infrastructure or other services outside the scope of web applications. Also, Denial of service attacks, Social engineering and physical Security tests were out of scope.

Limitations

Due to the nature of the black-box testing approach, the assessment was conducted with no prior knowledge of the internal architecture, configurations, or specifics of the target environment. As a result, certain internal controls and security measures that may be in place were not directly assessed. Additionally, the scope did not extend to testing any mobile application that may be associated with the web platform.

Objectives

The primary objectives of this penetration test were:

1. To identify and exploit potential vulnerabilities within the web application layer.
2. To evaluate the effectiveness of existing security controls in mitigating potential threats.
3. To assess the risk of unauthorized access, data exposure, or other security breaches.
4. To provide actionable recommendations for improving the overall security posture of the web infrastructure.

Methodology

The methodology employed in this penetration test adhered to industry best practices, utilizing a combination of established tools, techniques, and recognized standards and frameworks. The methodology adopted, aimed at ensuring a comprehensive and systematic evaluation of the web infrastructure, identifying potential vulnerabilities and providing actionable recommendations for strengthening the security posture.

Testing Approach:

The testing approach followed a **black-box testing methodology**, where no specific information or constraints were provided regarding the scope of the assessment. This simulates an external attacker with no prior knowledge of the internal environment, mirroring real-world threat scenarios.

Standards and Frameworks:

The testing process adhered to established industry standards and frameworks. The frameworks provided a structured approach to identifying and addressing potential security gaps. These includes:

- The Cyber Kill Chain is a concept that outlines the stages of a cyberattack from the initial reconnaissance phase to the final objective of the attacker. It provided a structured framework for understanding and analyzing the various steps an attacker might take in a targeted cyber intrusion.
- OWASP (Open Web Application Security Project) guidelines for web application security testing.
- NIST (National Institute of Standards and Technology) cybersecurity best practices.

Tools and Techniques:

A range of widely recognized penetration testing tools were leveraged to conduct the assessment. The tools were carefully selected based on their proven effectiveness and their applicability to web application security testing. Each tool played a crucial role in enabling a comprehensive

evaluation of potential vulnerabilities within the target web infrastructure. The tools includes but are not limited to:

1. **Reconnaissance tools:**
    a) **Urlscan.io** - was used to analyze the target website and gather information about domain infrastructure, requests, and external resources loaded by the application.
    b) **Nmap** - was employed for network discovery and vulnerability scanning to identify open ports and services.
    c) **Whatweb** - was used to identify technologies used by the web application such as web servers, frameworks, CMS platforms, and plugins
    d) **VirusTotal** - was used to analyze domains and URLs associated with the target for any known malicious activity or security reputation issues
    e) **Gobuste**r - was employed for web content discovery, helping identify hidden files and directories.
2. **Vulnerability analysis tools**
    a) **Burp Suite** - was utilized for comprehensive web application security testing, including vulnerability scanning, analysis, and manual testing.
    b) **OWASP ZAP** - was used to compare with the burp suite test results in automated and manual testing of web application security vulnerabilities.
    c) **Metasploit Framewor**k - was applied for identifying and exploiting known vulnerabilities in network services.
    d) **Sqlmap** - was specialized in detecting and exploiting SQL injection vulnerabilities.
    e) **Nikto** - was utilized for scanning web servers for known vulnerabilities and misconfigurations.
    f) **Hydra** - was applied for brute-force attacks on login form discovered
3. **Reporting tools**
    a) **Microsoft Word** – was used to document the penetration testing process, findings, and remediation recommendations in a structured report format.

b) **Screenshots and logging tools** – were used to capture proof-of-concept evidence of discovered vulnerabilities and support the analysis in the final report.

Target Information

Publicly available information:

The following information is available in publicly available sources:

- ★ Company Name: Pingbreakers Cybersecurity Company
- ★ Website: https://pingbreakers.com
- ★ Geo: Mumbai, India (IN)
- ★ Social Media Profiles: linkedin as https://www.linkedin.com/in/ping-breakers-20b098257/
- ★ Contact Information: None open
- ★ Employee Names and Titles: None Open

DNS Information:

The DNS records and findings for the target domain are as follows:

- ★ A Records: ***217.21.87.11 (AS47583 - AS-HOSTINGER, CY)***
- ★ CNAME Records:
- ★ MX Records:
- ★ TXT Records:

Network Information:

The target network architecture includes:

- Route: 217.21.80.0/20
- IPv4 : 217.21.87.11
- IPv6 : 2a02:4780:11:762:0:c63:aa01

General Info

Open in Search

Geo	Mumbai, India (IN) —
AS	AS47583 - AS-HOSTINGER, CY Note: An IP might be announced by multiple ASs. This is not shown.
Registrar	RIPENCC
Route	217.21.80.0/20 (Route of ASN)
IPv4	217.21.87.11
IPv6	2a02:4780:11:762:0:c63:aa01:2

Fig1:the general information results from the urlscan.io

Web Application Information:

The web application assessment revealed the following details:

- Technologies Used: HTML5, Frame, Script, X-UA-Compatible (IE=edge), Open Graph Protocol (website), Matomo (analytics), MetaGenerator: Gatsby 2.32.13, Nginx 1.18.0 (Ubuntu), LiteSpeed Web Server
- Content Management System (CMS): Gatsby 2.32.13 (static site generator)
- Server Operating System: Ubuntu linux
- HTTPServer: LiteSpeed , OpenResty
- The web page at the root directory (/) is powered by PHP version 7.4.33.
- Database: **MySQL server with version 5.5.5-10.5.19-MariaDB-cll-lve**
- Detected Vulnerabilities:
    - **403 Forbidden** response detected
    - **Title element contains newline(s)** (improper HTML formatting)
    - **Uncommon HTTP Header detected:** platform
    - **Information disclosure:** email address exposed in headers (debeaanvanhetleven@coopr.nl)

```
┌──(kali㉿zawaddie)-[~]
└─$ whatweb 37.97.226.36
http://37.97.226.36 [200 OK] Country[ROMANIA][RO], Email[debaanvanhetleven@coopr.nl], Frame, HTML5, HTTPServer[Ubuntu Linux][n
ginx/1.18.0 (Ubuntu)], IP[37.97.226.36], Matomo, MetaGenerator[Gatsby 2.32.13], Open-Graph-Protocol[website], Script, X-UA-Com
patible[ie=edge], YouTube, nginx[1.18.0]

┌──(kali㉿zawaddie)-[~]
└─$ whatweb 217.21.87.11
http://217.21.87.11 [403 Forbidden] Country[UNITED KINGDOM][GB], HTML5, HTTPServer[LiteSpeed], IP[217.21.87.11], LiteSpeed, Ti
tle[403 Forbidden][Title element contains newline(s)!], UncommonHeaders[platform]
```

Fig2: underlying technologies in the main domain and the subdomain use using whatweb

Other Relevant Information:

Additional noteworthy information discovered during the assessment:

- Third-party Services in Use: [List of Services]
- TLS Certificate: *Issued by R3 on October 8th 2023. Valid for: 3 months*
- Web Application Firewalls (WAFs): [Details of WAF, if applicable]
- Subdomains:
    1. lol.pingbreakers.com
    2. tojojo.pingbreakers.com
    3. pay.pingbreakers.com

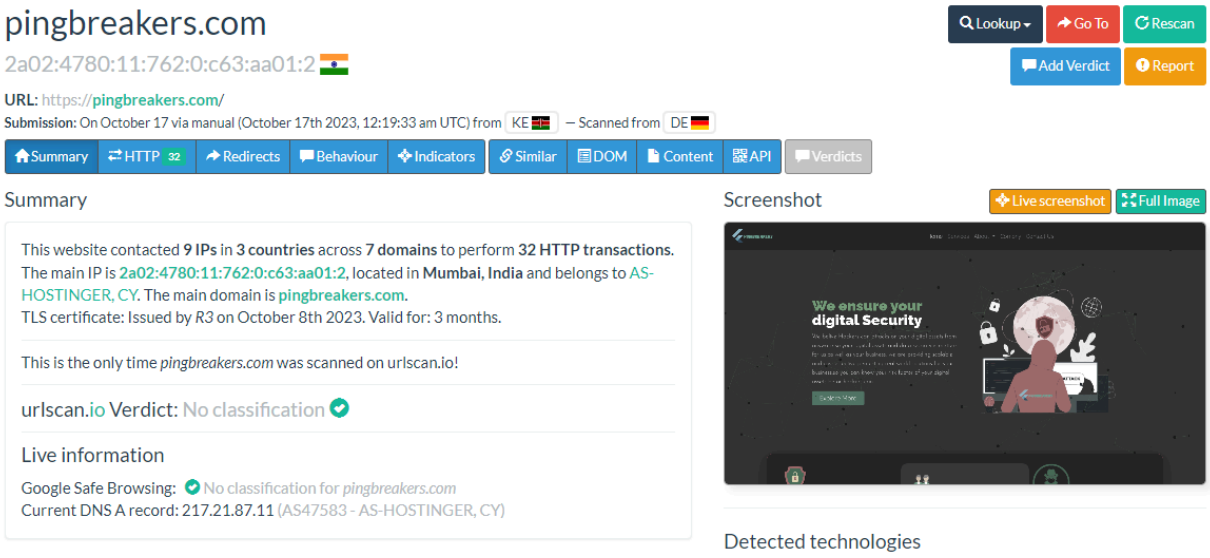


fig3: urlsacan.io results of the scan

Recently observed hostnames on 'pingbreakers.com'

Searching for newly observed domains and hostnames is possible on our urlscan Pro platform.

lol.pingbreakers.com | 2023-01-20 | tojojo.pingbreakers.com | 2023-01-17 | pingbreakers.com | 2022-10-14 | www.pingbreakers.com | 2022-10-14 | pay.pingbreakers.com | 2022-10-13 | www.pay.pingbreakers.com | 2022-10-13

fig4: discovered hostnames

Vulnerability Analysis and Findings

This is a detailed section that discusses the vulnerability assessment process and then explains the vulnerabilities and findings identified during the penetration test.

Vulnerability Analysis process:

STEP 1: Active Scanning for Host discovery

On normal scanning I noted that there was a firewall enabled to block any scan and block any IP address that tries to.

Thus I tried to bypass the Firewalls using Decoys., with this, I managed to Bypass that protection

```
┌──(kali㉿zawaddie)-[~/Desktop/H4U_PT]
└─$ sudo nmap -D 192.168.100.2,192.168.100.3,192.168.100.4,192.168.100.3 pingbreakers.com
Starting Nmap 7.94 ( https://nmap.org ) at 2023-10-11 15:15 EDT
Stats: 0:00:45 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 56.03% done; ETC: 15:17 (0:00:35 remaining)
Nmap scan report for pingbreakers.com (217.21.87.11)
Host is up (0.059s latency).
Other addresses for pingbreakers.com (not scanned): 2a02:4780:11:762:0:c63:aa01:2
Not shown: 993 filtered tcp ports (no-response)
PORT     STATE  SERVICE
21/tcp   open   ftp
22/tcp   closed ssh
80/tcp   open   http
443/tcp  open   https
3306/tcp open   mysql
7443/tcp open   oracleas-https
8443/tcp open   https-alt

Nmap done: 1 IP address (1 host up) scanned in 82.65 seconds
```

Fig5: nmap decoys scan results

OPEN PORTS:

Port	service	product
21	ftp	ProFTPD or KnFTPD
80	http	LiteSpeed
443	https	LiteSpeed
3306	msql	mySQL
7443	http	OpenResty web app server
8443	http	OpenResty web app server

See appendix A for comprehensive nmap results.

STEP 2: Service enumeration through Banner Grabbing

When a 3-way handshake that happens during an Nmap scan is complete, the server sends a banner for identification that serves to let the client know which service it is working with. I manipulated the banner from the respective services using the Banner grabbing technique.

The ***Banner grabbing*** was done by connecting to the SMTP server using ***netcat***, ***nc,*** grabbing the banners and intercepting the traffic using ***tcpdump*** to be able to see what Nmap didn't show .

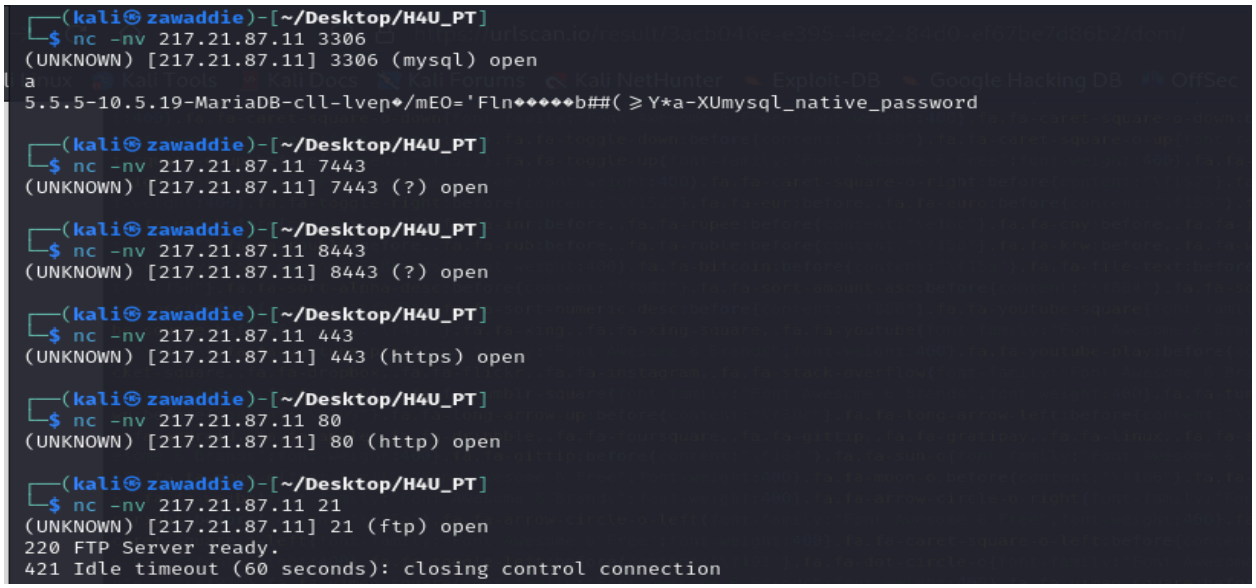


Fig 6: banner grabbing for the services on the 'pingbreakers.com' domain

Response from the MySQL server.:

5.5.5-10.5.19-MariaDB-cll-lve$_{p}$ ◆/mEO='Fln◆◆◆◆◆b##(>=Y*a-XUmysql_native_password.

This includes version information and possibly other details about the MySQL server. The information provided may include the server version (5.5.5-10.5.19-MariaDB-cll-lve), followed by additional details. The response might also include some characters that are not displayable or might be incorrectly encoded in the terminal. Additionally, there is also information related to the authentication method used (mysql_native_password), which indicates the password authentication plugin being used by the MySQL server.

The database server is running a 5.5.5 version of MySQL that is based on MariaDB 10.5.19

<u>STEP 3: Directory enumeration:</u>

Gobuster command line tool was employed for web content discovery, helping identify hidden files and directories.

A long list of files and directories was discovered, but all the files seemed similar as indicated by the same size though having different names. Also visiting the directories indicated that they had similar content that confirmed some form of accidental deletion.

```
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.git/HEAD            (Status: 403) [Size: 699]
/.htaccess            (Status: 403) [Size: 699]
/.hta                 (Status: 403) [Size: 699]
/.htpasswd            (Status: 403) [Size: 699]
/.svn/entries         (Status: 403) [Size: 699]
/.svn                 (Status: 403) [Size: 699]
/~adm                 (Status: 301) [Size: 707] [--> http://217.21.87.11/~adm/]
/~admin               (Status: 301) [Size: 707] [--> http://217.21.87.11/~admin/]
/~administrator       (Status: 301) [Size: 707] [--> http://217.21.87.11/~administrator/]
/~amanda              (Status: 301) [Size: 707] [--> http://217.21.87.11/~amanda/]
/~bin                 (Status: 301) [Size: 707] [--> http://217.21.87.11/~bin/]
/~ftp                 (Status: 301) [Size: 707] [--> http://217.21.87.11/~ftp/]
/~apache              (Status: 301) [Size: 707] [--> http://217.21.87.11/~apache/]
/~guest               (Status: 301) [Size: 707] [--> http://217.21.87.11/~guest/]
/~log                 (Status: 301) [Size: 707] [--> http://217.21.87.11/~log/]
/~httpd               (Status: 301) [Size: 707] [--> http://217.21.87.11/~httpd/]
/~http                (Status: 301) [Size: 707] [--> http://217.21.87.11/~http/]
/~lp                  (Status: 301) [Size: 707] [--> http://217.21.87.11/~lp/]
/~logs                (Status: 301) [Size: 707] [--> http://217.21.87.11/~logs/]
/~nobody              (Status: 301) [Size: 707] [--> http://217.21.87.11/~nobody/]
/~sys                 (Status: 301) [Size: 707] [--> http://217.21.87.11/~sys/]
/~root                (Status: 301) [Size: 707] [--> http://217.21.87.11/~root/]
/~mail                (Status: 301) [Size: 707] [--> http://217.21.87.11/~mail/]
/~operator            (Status: 301) [Size: 707] [--> http://217.21.87.11/~operator/]
/~test                (Status: 301) [Size: 707] [--> http://217.21.87.11/~test/]
/~sysadmin            (Status: 301) [Size: 707] [--> http://217.21.87.11/~sysadmin/]
/~sysadm              (Status: 301) [Size: 707] [--> http://217.21.87.11/~sysadm/]
/~tmp                 (Status: 301) [Size: 707] [--> http://217.21.87.11/~tmp/]
/~user                (Status: 301) [Size: 707] [--> http://217.21.87.11/~user/]
/~webmaster           (Status: 301) [Size: 707] [--> http://217.21.87.11/~webmaster/]
/~www                 (Status: 301) [Size: 707] [--> http://217.21.87.11/~www/]
Progress: 4614 / 4615 (99.98%)
```

fig 7: domain directory listing

<u>STEP 6: Subdomain Enumeration:</u>

Out of the three subdomains discovered by the urlscan.io. ***lol.pingbreakers.com, tojojo.pingbreakers.com, pay.pingbreakers.com***, only one of them was discovered while using the OWASP amass tool. The ***lol.pingbreakers.com*** subdomain.

The other two were unreachable even through the web browser, so further enumeration was concentrated on the ***lol.pingbreakers.com*** subdomain.

```
┌──(kali㉿zawaddie)-[~]
└─$ amass enum -d pingbreakers.com
pingbreakers.com (FQDN) --> mx_record --> smtp.secureserver.net (FQDN)
pingbreakers.com (FQDN) --> mx_record --> mailstore1.secureserver.net (FQDN)
pingbreakers.com (FQDN) --> ns_record --> ns1.dns-parking.com (FQDN)
pingbreakers.com (FQDN) --> ns_record --> ns2.dns-parking.com (FQDN)
pingbreakers.com (FQDN) --> a_record --> 217.21.87.11 (IPAddress)
pingbreakers.com (FQDN) --> aaaa_record --> 2a02:4780:11:762:0:c63:aa01:2 (IPAddress)
www.pingbreakers.com (FQDN) --> cname_record --> pingbreakers.com (FQDN)
217.21.80.0/20 (Netblock) --> contains --> 217.21.87.11 (IPAddress)
0 (ASN) --> managed_by --> Not routed (RIROrganization)
0 (ASN) --> announces --> 217.21.80.0/20 (Netblock)
smtp.secureserver.net (FQDN) --> a_record --> 216.69.141.81 (IPAddress)
smtp.secureserver.net (FQDN) --> a_record --> 68.178.213.203 (IPAddress)
smtp.secureserver.net (FQDN) --> a_record --> 68.178.213.37 (IPAddress)
ns2.dns-parking.com (FQDN) --> a_record --> 162.159.25.42 (IPAddress)
ns2.dns-parking.com (FQDN) --> aaaa_record --> 2400:cb00:2049:1::a29f:192a (IPAddress)
lol.pingbreakers.com (FQDN) --> a_record --> 37.97.226.36 (IPAddress)
lol.pingbreakers.com (FQDN) --> aaaa_record --> 2a02:4780:11:762:0:c63:aa01:2 (IPAddress)
2400:cb00:2049::/48 (Netblock) --> contains --> 2400:cb00:2049:1::a29f:192a (IPAddress)
13335 (ASN) --> managed_by --> CLOUDFLARENET - Cloudflare, Inc. (RIROrganization)
13335 (ASN) --> announces --> 2400:cb00:2049::/48 (Netblock)
37.97.128.0/17 (Netblock) --> contains --> 37.97.226.36 (IPAddress)
2a02:4780:11::/48 (Netblock) --> contains --> 2a02:4780:11:762:0:c63:aa01:2 (IPAddress)
216.69.140.0/22 (Netblock) --> contains --> 216.69.141.81 (IPAddress)
20857 (ASN) --> managed_by --> TRANSIP-AS Amsterdam, the Netherlands (RIROrganization)
20857 (ASN) --> announces --> 37.97.128.0/17 (Netblock)
47583 (ASN) --> managed_by --> AS-HOSTINGER, CY (RIROrganization)
47583 (ASN) --> announces --> 2a02:4780:11::/48 (Netblock)
398101 (ASN) --> managed_by --> AS398101 (RIROrganization)
```

Fig 6:subdomain enumeration results using OWASP Amass command line tool

<u>STEP 7: Scanning the subdomain for host and open ports discovery</u>

A basic nmap scan revealed the open ports and the services running in the *lol.pingbreakers.com* subdomain.

Three ports are open**: 80, 443, 49122**

Using the banner grabbing technique reveals the services and the versions on the open ports:

```
┌──(kali㉿zawaddie)-[~]
└─$ nc -nv 37.97.226.36 49122
(UNKNOWN) [37.97.226.36] 49122 (?) open
SSH-2.0-OpenSSH_8.9p1 Ubuntu-3ubuntu0.3

┌──(kali㉿zawaddie)-[~]
└─$ nc -nv 37.97.226.36 80
(UNKNOWN) [37.97.226.36] 80 (http) open

┌──(kali㉿zawaddie)-[~]
└─$ nc -nv 37.97.226.36 443
(UNKNOWN) [37.97.226.36] 443 (https) open
```

Fig 7: Banner grabbing for the services on the 'lol.pingbreakers.com' subdomain

<u>STEP 8: Directory enumeration in the subdomain:</u>

```
┌──(kali㉿zawaddie)-[~]
└─$ gobuster dir -u http://lol.pingbreakers.com/ -w /usr/share/dirb/wordlists/common.txt\

===============================================================
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
===============================================================
[+] Url:                     http://lol.pingbreakers.com/
[+] Method:                  GET
[+] Threads:                 10
[+] Wordlist:                /usr/share/dirb/wordlists/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.6
[+] Timeout:                 10s
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/404                  (Status: 301) [Size: 178] [--> http://lol.pingbreakers.com/404/]
/admin                (Status: 301) [Size: 178] [--> http://lol.pingbreakers.com/admin/]
/assets               (Status: 301) [Size: 178] [--> http://lol.pingbreakers.com/assets/]
/favicon.ico          (Status: 200) [Size: 198]
/icons                (Status: 301) [Size: 178] [--> http://lol.pingbreakers.com/icons/]
/index.html           (Status: 200) [Size: 82537]
/robots.txt           (Status: 200) [Size: 24]
/static               (Status: 301) [Size: 178] [--> http://lol.pingbreakers.com/static/]
Progress: 4614 / 4615 (99.98%)
===============================================================
Finished
===============================================================
```

Fig8: gobuster results of subdomain directory enumeration

Directory listing in the subdomain reveals: ***404/, admin/, assets/ icons/, robots.txt/, static/favicon.ico***/

(i) /404/ directory: nothing alarming was found

(ii) /admin/ directory: the admin panel uses Netfly CMS

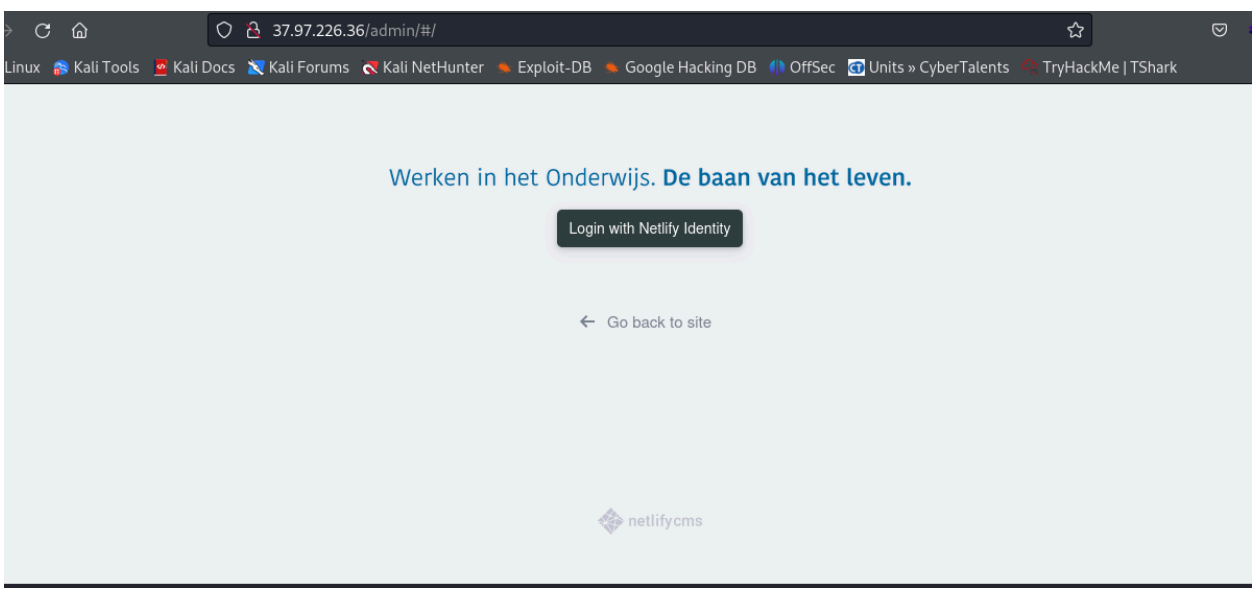


Fig 9:the /admin directory details

(iii) /assets, /icons /static directories

1. **<u>Reveals incorrect error handling</u>.**

It reveals the server in use and its version

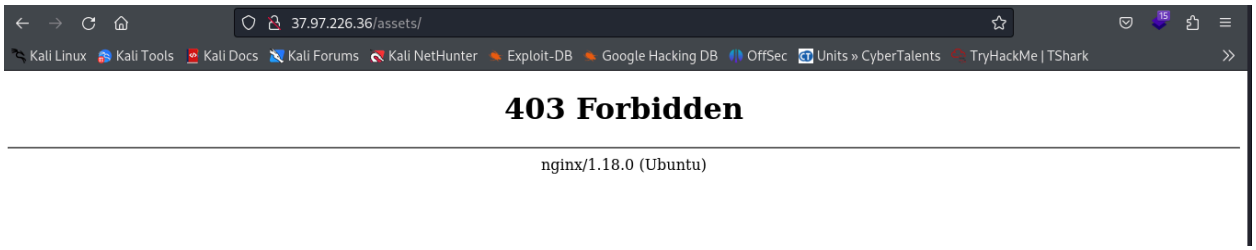
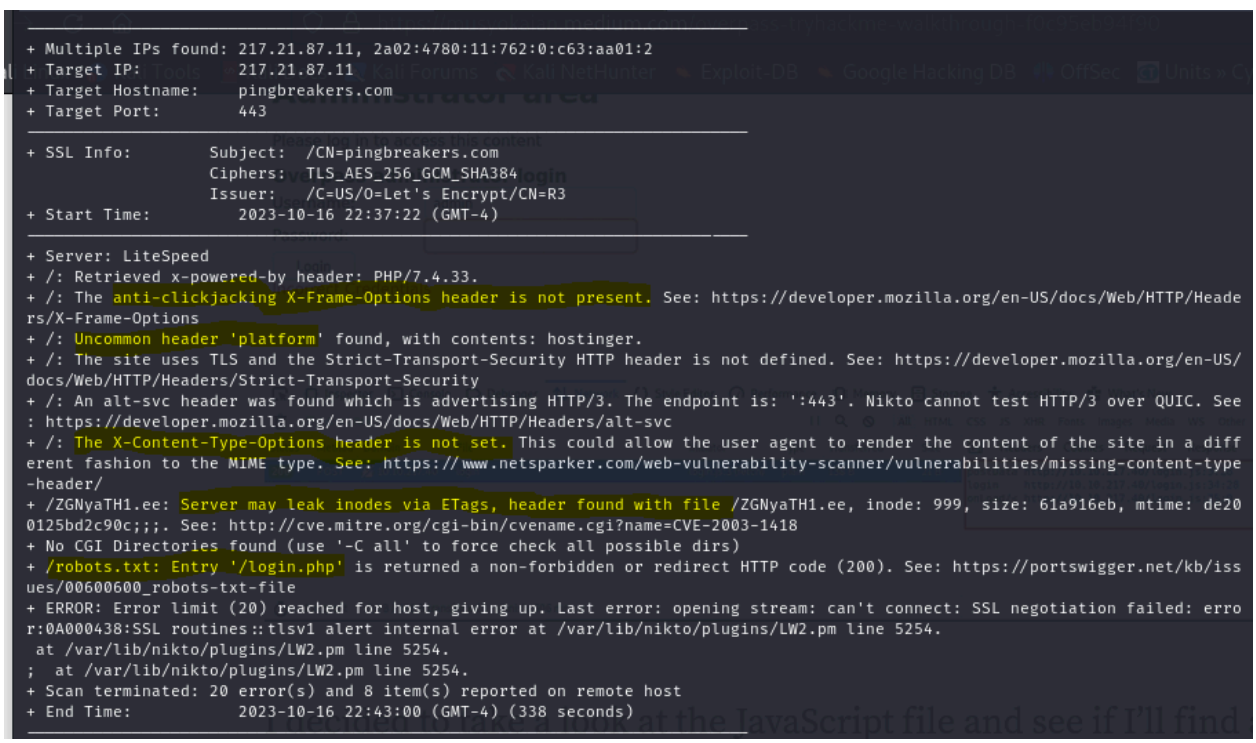


Fig 10: the /assets directory revealing incorrect error handling

<u>STEP 9: Vulnerability scanning:</u>

The nikto command line tools revealed various vulnerabilities, issues and misconfigurations as indicated by the screenshot below;



```
+ Multiple IPs found: 217.21.87.11, 2a02:4780:11:762:0:c63:aa01:2
+ Target IP:          217.21.87.11
+ Target Hostname:    pingbreakers.com
+ Target Port:        443
---------------------------------------------------------------------------
+ SSL Info:        Subject:  /CN=pingbreakers.com
                   Ciphers:  TLS_AES_256_GCM_SHA384
                   Issuer:   /C=US/O=Let's Encrypt/CN=R3
+ Start Time:         2023-10-16 22:37:22 (GMT-4)
---------------------------------------------------------------------------
+ Server: LiteSpeed
+ /: Retrieved x-powered-by header: PHP/7.4.33.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Heade
rs/X-Frame-Options
+ /: Uncommon header 'platform' found, with contents: hostinger.
+ /: The site uses TLS and the Strict-Transport-Security HTTP header is not defined. See: https://developer.mozilla.org/en-US/
docs/Web/HTTP/Headers/Strict-Transport-Security
+ /: An alt-svc header was found which is advertising HTTP/3. The endpoint is: ':443'. Nikto cannot test HTTP/3 over QUIC. See
: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/alt-svc
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a diff
erent fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type
-header/
+ /ZGNyaTH1.ee: Server may leak inodes via ETags, header found with file /ZGNyaTH1.ee, inode: 999, size: 61a916eb, mtime: de20
0125bd2c90c;;;. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ /robots.txt: Entry '/login.php' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/iss
ues/00600600_robots-txt-file
+ ERROR: Error limit (20) reached for host, giving up. Last error: opening stream: can't connect: SSL negotiation failed: erro
r:0A000438:SSL routines::tlsv1 alert internal error at /var/lib/nikto/plugins/LW2.pm line 5254.
 at /var/lib/nikto/plugins/LW2.pm line 5254.
;  at /var/lib/nikto/plugins/LW2.pm line 5254.
+ Scan terminated: 20 error(s) and 8 item(s) reported on remote host
+ End Time:           2023-10-16 22:43:00 (GMT-4) (338 seconds)
---------------------------------------------------------------------------
```

Fig 11: Nikto vulnerability scanner detailed results

Findings:

The findings here provide valuable insights into the web server's misconfigurations and potential security vulnerabilities. Addressing these identified issues will enhance the security posture of the website.

Finding F01: Weak password policy

Severity: HIGH

Description:

The password found while brute forcing the login page was **'hardrock**' a plain word. This is an indication of weak password policy

This also indicates that passwords are stored in plain text.

Proof of Concept:

These credentials were obtained through a brute force attack using wordlists of common usernames and passwords.

Impact:

The impact of weak passwords is quite severe to the organization because:

1. Increased Risk of Unauthorized Access through password guessing or cracking.
2. Weak passwords can result in data breaches, where sensitive information is exposed or stolen
3. User accounts with weak passwords are more susceptible to being compromised. Attackers can impersonate legitimate users and misuse their privileges.
4. A weak password policy undermines other security measures.
5. Increased Vulnerability to Brute-Force Attacks:

Recommendations:

I would recommend that:

a) Require passwords to be of a minimum length (e.g., at least 12 characters) and include a combination of uppercase and lowercase letters, numbers, and special characters.
b) Enforce the prohibition of easily guessable passwords, or common words.
c) Encourage or require the use of multi-factor authentication, which adds an extra layer of security by requiring additional authentication factorsPassword Managers.
d) Encourage the use of password management tools that can generate and store complex passwords securely.
e) Consider storing hashes other than plain text

Complex password policies should be accompanied by user-friendly mechanisms to help users remember or securely manage their passwords.

References:

[1] NIST Special Publication 800-63B : Digital Identity Guidelines
[2] OWASP Password Storage Cheat Sheet
[3] NCSC Password Guidance, National Cyber Security Centre
[4] CISA Password Tips: Cybersecurity & Infrastructure Security Agency

Finding F02: Missing Security Headers

Severity: MEDIUM

1: X-Frame-options Header not set.

Description:

The anti-clickjacking security header 'X-Frame-Options' is not present. This header helps prevent clickjacking attacks.

This can be classified as a Security Misconfiguration according to OWASP Top 10.

Proof of Concept:

The absence of the X-Frame-Options header is not a specific vulnerability that can be exploited in the same way as traditional software vulnerabilities. Instead, it's a security best practice to prevent clickjacking attacks.

Clickjacking attacks rely on tricking a user into interacting with a web page in a way they didn't intend, often by placing a transparent iframe over a legitimate page. The X-Frame-Options header helps prevent this by instructing the browser to deny or restrict the ability to display the page in a frame.

There's no specific "proof of concept" (PoC) for the absence of the X-Frame-Options header, as it's more about implementing a security measure rather than exploiting a particular vulnerability. Its absence can be verified by inspecting the HTTP response headers of the webpage. If the header is not present, it means the site is not protected against clickjacking attacks.Check for the presence of this header using automated tools or manual inspection of the HTTP response headers.

Impact:

This vulnerability has the potential to expose the application to clickjacking attacks, which can lead to unauthorized actions on behalf of users. While not as severe as some other vulnerabilities, it can still have a notable impact on security within the organization.

Recommendations:

a) As a remedy this requires the implementation of the X-Frame-Options header in the web server's configuration. It's generally recommended to include this header with an appropriate value (such as DENY or SAMEORIGIN) to protect against such attacks by controlling which pages can embed the content.
   Ensure that the web server includes the X-Frame-Options header in its HTTP response.
   'DENY' will prevent the page from being displayed in a frame regardless of where the request comes from. 'SAMEORIGIN' will allow the page to be displayed in a frame as long as the request comes from the same origin (same domain).

b) Regularly Test for Clickjacking Vulnerabilities to ensure that the X-Frame-Options header is implemented correctly and effectively protecting against clickjacking attacks.

2: X-Content-Type-Options Header Not set

Description:

The 'X-Content-Type-Options' header helps prevent certain types of attacks by ensuring that the browser interprets files as the correct MIME type. When correctly configured, It helps prevent MIME type sniffing attacks. The 'X-Content-Type-Options' not being sent indicates a security misconfiguration.

Proof of Concept:

The X-Content-Type-Options header is a security feature that helps protect against MIME type sniffing attacks. These attacks occur when a browser attempts to interpret a file as a different MIME type than what the server specifies. This can potentially lead to security vulnerabilities, particularly with files like scripts or executables.

Impact:

This misconfiguration can lead to MIME type sniffing attacks, potentially allowing attackers to disguise malicious content as benign. While not as severe as critical vulnerabilities, it can still pose a risk to security.

Recommendations:

To address this vulnerability, you should implement the X-Content-Type-Options header in your web server configuration. This header should be set to 'nosniff', which instructs the browser not to interpret files in a way that could lead to a MIME type mismatch.

References:

3: Strict-Transport-Security Header not defined

Severity:

Description:

The Strict-Transport-Security header, which enforces the use of HTTPS, is not defined. This header helps protect against certain types of attacks. This is a security header misconfiguration. It's best practice to enforce the use of HTTPS.

Impact:

This misconfiguration could potentially expose the application to man-in-the-middle attacks or downgrade attacks. While not as severe as critical vulnerabilities, it's still important for enforcing secure communication.

Recommendations:

Set the Strict-Transport-Security header in the web server's configuration to enforce the use of HTTPS

Finding F03: Server banners Disclosure

Severity: LOW

Description:

Service enumeration on the open ports unveils that unveils underlying technology within the website

Proof of Concept:

From fig 6, the database server is running a 5.5.5 version of MySQL that is based on MariaDB 10.5.19. Additionally, there is also information related to the authentication method used (mysql_native_password), which indicates the password authentication plugin being used by the MySQL server.

Fig 7 of the subdomain service enumeration through banner grabbing unveils SSH-2.0 OPenSSH-8.9p1 Ubuntu-3Ubuntu0.3. This banner is openly revealing information about the SSH server's implementation (OpenSSH), version (8.9p1), and the underlying operating system (Ubuntu, version 3Ubuntu0.3). While this information can be useful for legitimate users and administrators, it also provides potential attackers with details that they might use to target specific vulnerabilities associated with the disclosed versions. Hence, minimizing this information (commonly referred to as banner hiding) can be a security best practice to reduce the attack surface.

This information can lead to further enumeration and lead to potential exploitation. For instance, **t**he MySql 5.5.5 is a component used in the website that contains an exploitable vulnerability Ie. Remote Code Execution / privilege escalation as indicated by searchsploit and google search.

```
└─$ searchsploit mariadb
---------------------------------------------------------------------------------------------------------------
 Exploit Title                                                                                   |  Path
---------------------------------------------------------------------------------------------------------------
MariaDB 10.2 - 'wsrep_provider' OS Command Execution                                             | linux/local/49765.txt
MariaDB Client 10.1.26 - Denial of Service (PoC)                                                 | linux/dos/45901.txt
MySQL / MariaDB - Geometry Query Denial of Service                                               | linux/dos/38392.txt
MySQL / MariaDB / PerconaDB 5.5.51/5.6.32/5.7.14 - Code Execution / Privilege Escalation         | linux/local/40360.py
MySQL / MariaDB / PerconaDB 5.5.x/5.6.x/5.7.x - 'mysql' System User Privilege Escalation /       | linux/local/40678.c
MySQL / MariaDB / PerconaDB 5.5.x/5.6.x/5.7.x - 'root' System User Privilege Escalation          | linux/local/40679.sh
Oracle MySQL / MariaDB - Insecure Salt Generation Security Bypass                                | linux/remote/38109.pl
---------------------------------------------------------------------------------------------------------------
```

```
I. VULNERABILITY
------------------------

MySQL / MariaDB / Percona - Remote Root Code Execution / Privilege Escalation (0day)

MySQL  <= 5.7.14
          5.6.32
          5.5.51

MySQL clones are also affected, including:

MariaDB

Percona
```

Impact:

1. Through unauthorized access or exploitation, an attacker could potentially gain unauthorized access to the server, execute malicious code, or perform other malicious actions.
2. Vulnerabilities in the server version could lead to exposure or manipulation of sensitive data stored on the server.
3. Exploiting a vulnerability in the server may result in service disruption, potentially affecting the availability and functionality of the application or website.

Recommendations:

a) Disable Server Banner to minimize information leakage by configuring the server to suppress or obfuscate version information in its responses. This makes it more difficult for attackers to determine the specific software version.

For the services running in this website, you can hide or obfuscate banners by the following guidance:

- ❖ MySQL Database Server: In the MySQL configuration file (**my.cnf**), you can use the banner directive to specify a custom banner that will be displayed when connecting to the server.

- ❖ SSH Server: In the SSH configuration file **(sshd_config),** you can use the Banner directive to specify a custom message that is displayed to users upon connection. This can be used to replace or obfuscate the default SSH banner.

b) Always patch or update the server software to a version that does not have the known vulnerability.

c) Implement Web Application Firewall (WAF) to help protect against known vulnerabilities by filtering and monitoring HTTP traffic between a web application and the Internet.

d) Implement strong authentication, enforce access controls, and regularly monitor for security incidents.

References:

[1] OWASP Web Application Security Testing Guide - Information Leakage

[2] NIST Special Publication 800-163 - Vetting the Security of Mobile Applications: NIST SP 800-163

[3] SANS Institute Reading Room - Web Application Hardening: Reducing Information Leakage: SANS Reading Room

[4] Official Documentation for Web Servers and Services (e.g., lightSpeed,OpenSSH, MySQL) for their respective configuration options related to banner hiding.

Finding F04: Incorrect error handling

Severity: LOW

Description:

The application exhibits a vulnerability related to incorrect error handling, which discloses sensitive information about the server software. Specifically, it has been identified that the server is running Nginx version 1.18.0 on an Ubuntu platform. This information disclosure could potentially be leveraged by attackers to target known vulnerabilities associated with this specific server configuration.

Proof of Concept:

Conducting an HTTP request to /assets, /icons /static directories indicates the resources are forbidden. Furthermore, it indicates incorrect error handling because while reporting the error to the client, it also reveals the server in use and its version.

This is proved through fig 10.

Impact:

The exposure of specific server software and version information can potentially increase the risk of targeted attacks. If there are known vulnerabilities associated with Nginx 1.18.0 on Ubuntu, attackers could attempt to exploit them, potentially leading to unauthorized access or other malicious activities

Recommendations:

a) Customize error messages to provide minimal information to users and prevent the disclosure of server details.
b) Ensure that the Nginx server is updated to the latest version with all security patches applied to mitigate known vulnerabilities.
c) Conduct regular security audits to identify and address any potential vulnerabilities in the application logic, including error handling.

References:

[1] Official documentation for the technologies and tools in use (e.g., Apache, Nginx, OpenSSH, Ubuntu).
[2] Security Standards and Best Practices: OWASP and NIST.

Finding F05: /robots.txt Entry '/login.php'

Severity: LOW

Description: /robots.txt Entry '/login.php' as revealed by Nikto scanner

The '/robots.txt' file indicates that there is a '/login.php' page, which is returning a non-forbidden HTTP code (200). This might indicate that the login page is accessible to web crawlers.This can be classified as **Sensitive information leakage**

The robots.txt file provides instructions to web crawlers or search engine bots about which pages or sections of a website should not be crawled or indexed. If the robots.txt file reveals a file like the **login.php** and disallows it, it could potentially pose a security risk.

In the https://pingbreakers root directory, the robots.txt file disallows a **login.php** file from web crawlers. This makes malicious actors curious and they may use this information to focus their efforts on finding vulnerabilities in the login process. They might attempt to carry out brute force attacks or other login-related exploits

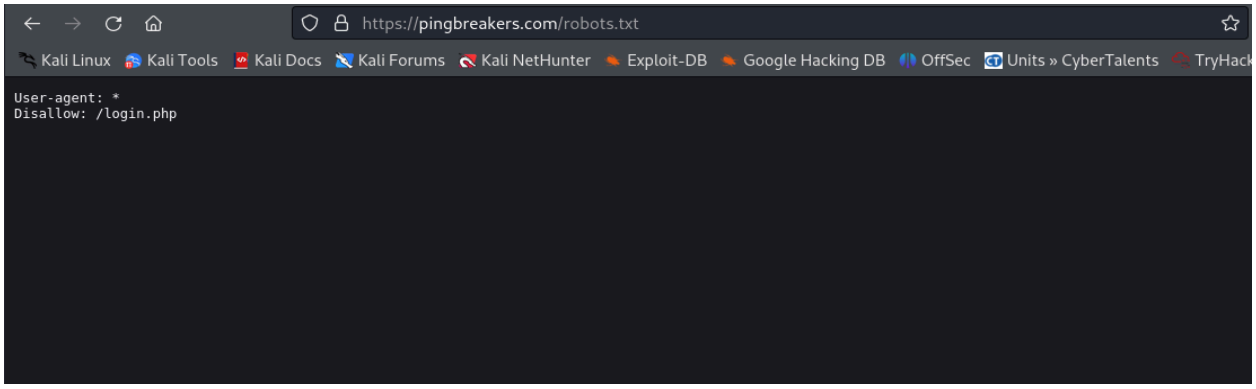


Fig 12 : the /robots.txt file revealing the instructions to the web crawlers

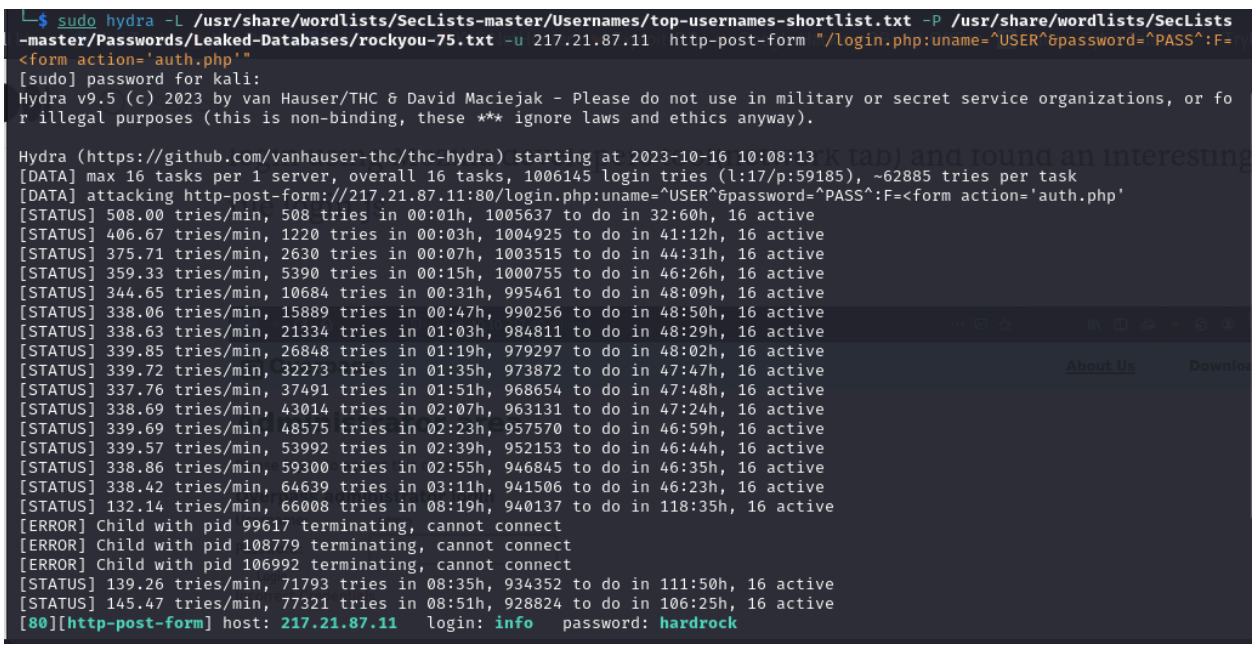
<u>Proof of Concept</u>: Bruteforce attack

Tool: Hydra

Command:

sudo hydra -L /usr/share/wordlists/SecLists-master/Usernames/top-usernames-shortlist.txt -P /usr/share/wordlists/SecLists-master/Passwords/Leaked-Databases/rockyou-75.txt -u 217.21.87.11 http-post-form "/login.php:uname=^USER^&password=^PASS^:F=<form action='auth.php'

Results of the brute force attack reveal login password for the current user*:*



```
└─$ sudo hydra -L /usr/share/wordlists/SecLists-master/Usernames/top-usernames-shortlist.txt -P /usr/share/wordlists/SecLists
-master/Passwords/Leaked-Databases/rockyou-75.txt -u 217.21.87.11 http-post-form "/login.php:uname=^USER^&password=^PASS^:F=
<form action='auth.php'"
[sudo] password for kali:
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or fo
r illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2023-10-16 10:08:13
[DATA] max 16 tasks per 1 server, overall 16 tasks, 1006145 login tries (l:17/p:59185), ~62885 tries per task
[DATA] attacking http-post-form://217.21.87.11:80/login.php:uname=^USER^&password=^PASS^:F=<form action='auth.php'
[STATUS] 508.00 tries/min, 508 tries in 00:01h, 1005637 to do in 32:60h, 16 active
[STATUS] 406.67 tries/min, 1220 tries in 00:03h, 1004925 to do in 41:12h, 16 active
[STATUS] 375.71 tries/min, 2630 tries in 00:07h, 1003515 to do in 44:31h, 16 active
[STATUS] 359.33 tries/min, 5390 tries in 00:15h, 1000755 to do in 46:26h, 16 active
[STATUS] 344.65 tries/min, 10684 tries in 00:31h, 995461 to do in 48:09h, 16 active
[STATUS] 338.06 tries/min, 15889 tries in 00:47h, 990256 to do in 48:50h, 16 active
[STATUS] 338.63 tries/min, 21334 tries in 01:03h, 984811 to do in 48:29h, 16 active
[STATUS] 339.85 tries/min, 26848 tries in 01:19h, 979297 to do in 48:02h, 16 active
[STATUS] 339.72 tries/min, 32273 tries in 01:35h, 973872 to do in 47:47h, 16 active
[STATUS] 337.76 tries/min, 37491 tries in 01:51h, 968654 to do in 47:48h, 16 active
[STATUS] 338.69 tries/min, 43014 tries in 02:07h, 963131 to do in 47:24h, 16 active
[STATUS] 339.69 tries/min, 48575 tries in 02:23h, 957570 to do in 46:59h, 16 active
[STATUS] 339.57 tries/min, 53992 tries in 02:39h, 952153 to do in 46:44h, 16 active
[STATUS] 338.86 tries/min, 59300 tries in 02:55h, 946845 to do in 46:35h, 16 active
[STATUS] 338.42 tries/min, 64639 tries in 03:11h, 941506 to do in 46:23h, 16 active
[STATUS] 132.14 tries/min, 66008 tries in 08:19h, 940137 to do in 118:35h, 16 active
[ERROR] Child with pid 99617 terminating, cannot connect
[ERROR] Child with pid 108779 terminating, cannot connect
[ERROR] Child with pid 106992 terminating, cannot connect
[STATUS] 139.26 tries/min, 71793 tries in 08:35h, 934352 to do in 111:50h, 16 active
[STATUS] 145.47 tries/min, 77321 tries in 08:51h, 928824 to do in 106:25h, 16 active
[80][http-post-form] host: 217.21.87.11   login: info   password: hardrock
```

Fi 13: hydra bruteforce on the login.php page

<u>Impact:</u>

The impact of this vulnerability can be severe especially when exploited and it allows successful login. The impacts to the organization, ranges from immediate security breaches to long term consequences.

Potential impacts may include:

1. Unauthorized access leading to data theft, modification or destruction
2. Data breaches leading to exposure of sensitive data leading to legal and financial liabilities and reputation damage.
3. User accounts may be compromised, leading to potential misuse of internal resources, or unauthorized actions on behalf of legitimate users.
4. Loss of business due to reputational damage

Recommendations:

You can prevent a page from being crawled by search engines without listing it in the robots.txt file by using the **robots meta tag**. The ***robots meta tag*** lets you utilize a granular, page-specific approach to controlling how an individual page should be indexed and served to users in Google Search results.

a) **Meta Tag Noindex:**

In the <head> section of your HTML code, you can include a <meta> tag with the noindex directive. This tells search engines not to index the page.

```
<meta name="robots" content="noindex">
```

b) **X-Robots-Tag:**

You can send an ***X-Robots-Tag*** HTTP header with a ***noindex*** directive from your server. This method is especially useful for pages generated dynamically or protected by authentication.

```
header('X-Robots-Tag: noindex'
```

References:

[1] Google's Official Documentation: Using meta tags to block access to your site and Robots meta tag and X-Robots-Tag HTTP header specifications

[2] Mozilla Developer Network (MDN) Documentation: Meta tag and X-Robots-Tag

[3] Search Engine Optimization (SEO) Guides:Moz's The Beginner's Guide to SEO

Finding F06: Uncommon header ‘platform’

Severity: LOW

Description:

An uncommon header named 'platform' was found with the value 'hostinger'. This might provide information about the hosting environment.

This can be classified as information leakage. It could potentially reveal information about the hosting platform, which may be useful for attackers.

Proof of Concept:

When Nikto identifies an uncommon header named 'platform', it means that the web server is returning a non-standard HTTP header named 'platform' in its response. Standard headers are well-known and widely used, but an uncommon header could indicate a custom or less commonly used configuration.

The presence of an uncommon 'platform' header could suggest information about the underlying hosting platform. This might include details about the server software, operating system, or other environment-specific information.

Impact:

This finding, while uncommon, does not directly indicate a security vulnerability. It can be categorized as low severity because it provides limited information about the hosting platform, which may have minimal impact on security. However, It contributes to the overall attack surface. It provides additional information that attackers can potentially leverage in combination with other vulnerabilities or techniques.

Recommendations:

a) Evaluate the necessity of the 'platform' header. If it's not essential for the application's functionality, consider removing it from the server's response.
b) Review server configurations and ensure that custom headers provide value without exposing sensitive information.

References:

[1] OWASP Secure Headers Project
[2] NIST Special Publication 800-53: NIST SP 800-53
[3] Mozilla Developer Network (MDN) - HTTP MDN Web Docs - HTTP Headers

Finding F07: File Path Exposure via E-Tags

Severity: LOW

Description:

A potential file path exposure vulnerability was identified. The server may be leaking inode information via ETags. This could potentially be a

This is a potential information leakage issue. It could expose details about the server's file system structure.

Impact:

This vulnerability can potentially expose details about the server's file system structure, which may aid attackers in crafting more targeted attacks. While not as severe as critical vulnerabilities, it represents a notable information exposure risk.

Recommendations:

Consider disabling ETags if they are not essential. If needed, use strong ETags generated by a secure hash function.

Finding F08: alt-svc Header

Severity: INFORMATIONAL

Description:

An 'alt-svc' header was found advertising HTTP/3, indicating support for the next-generation HTTP protocol. Nikto is unable to test HTTP/3 over QUIC.

Impact:

This finding, while informational, does not directly indicate a security vulnerability. It simply reveals support for the next-gen HTTP protocol, which may not have an immediate impact on security.

Recommendations:

alt-svc Header Advertising HTTP/3:

This indicates support for the next-gen HTTP protocol (HTTP/3), which could reveal information about the server's capabilities.

If the exposure of HTTP/3 support is not intended, consider reviewing server configurations to limit the information disclosed.

Finding F09: Unpresent CGI Directories

Severity: INFORMATIONAL

Description:

No CGI directories were found. Nikto did not detect any common directories where CGI scripts might be located.

This can be classified as Lack of Function Level Access Control

This is a neutral finding indicating that no CGI directories were found. It doesn't necessarily represent a vulnerability.

Impact:

This is a neutral finding and doesn't directly indicate a vulnerability. It's categorized as low severity because it's a neutral result, indicating no CGI directories were found, which doesn't represent a security risk in itself.

Recommendations:

This is a neutral finding indicating that no CGI directories were found. It doesn't necessarily represent a vulnerability.

No specific action needed as this is not a security vulnerability.

Finding F10: SSL Negotiation failure:

Severity: MEDIUM

Description:

This is a technical error related to SSL negotiation. It's not a vulnerability in itself, but could indicate a potential issue with the SSL configuration.

Impact:

This technical error related to SSL negotiation could potentially lead to issues with secure communication. While it's not a vulnerability in itself, it indicates a potential issue with SSL configuration, which is important for overall security.

Recommendations:

Investigate and resolve the SSL negotiation failure, which could be due to misconfigured SSL settings or network issues.

Risk Assessment

Risk summary:

Finding ID	Issue	Vulnerability	likelihood/impact	Possible Risk	Reasoning
F01	/robots.txt Entry '/login.php'	Information Leakage	High/High	High	The exposure of the login page could lead to potential unauthorized access.
F02	Weak password policy	Authentication Weakness	High/High	High	Weak passwords increase the likelihood of successful brute-force attacks.
F03	Enabled Server Banners.	Information Leakage	Medium/High	Low-Medium	While information exposure is possible, the risk is relatively medium due to high likelihood.

F04	Incorrect error handling	Application Logic Vulnerability	Low-Medium/ Medium	Low-Medium	Potential exposure of sensitive information, but likelihood and impact are moderate.
F05	X-Frame-Options Header not set	Security Misconfiguration	Medium/Medium	Medium	Clickjacking risk exists, but likelihood and impact are moderate.
F06	X-Content-Type-Options Header Not set	Security Misconfiguration	Medium/Medium	Medium	Risk of MIME sniffing attacks, but likelihood and impact are moderate.
F07	Uncommon header 'platform'	Information Leakage	Low/Low	Low	Exposure of hosting platform info is possible, but the risk is relatively low.
F08	File Path Exposure via E-Tags	Information Leakage	Low-Medium/Medium	Low-Medium	Exposure of server file paths is possible, but likelihood and impact are moderate.
F09	Strict-Transport-Security Header not defined	Security Misconfiguration	Medium/Medium	Medium	Risk of MITM attacks, but likelihood and impact are moderate.
F10	alt-svc Header	Information Leakage	Low/Low	Low	Exposure of server capabilities is possible, but the risk is relatively low.
F11	Unpresent CGI Directories	Lack of Function Level Access Control	Low/Low	Low	Potential for unauthorized access to CGI directories, but likelihood and impact are low.
F12	SSL Negotiation failure	Transport Layer Protection	Medium/Medium	Medium	Risk of MITM attacks, but likelihood and impact are moderate.

Risk Classification and Scoring

Finding ID	Issue	Vulnerability	Threat	Consequence	likelihood	Impact	Risk Score
F01	/robots.txt Entry '/login.php'	Information Leakage	Unauthorized Access	Potential exposure of login page	3	3	9
F02	Weak password policy	Authentication Weakness	Brute-Force Attack	Increased risk of unauthorized access	3	3	9
F03	Unveiling of server Technology and version	Information Leakage	Successful Reconnaissance	Potential for targeted attacks	1	1	1
F04	Incorrect error handling	Application Logic Vulnerability	Information Disclosure	Potential exposure of sensitive information	2	2	4
F05	X-Frame-Options Header not set	Security Misconfiguration	Clickjacking	Risk of clickjacking attacks	2	2	4
F06	X-Content-Type-Options Header Not set	Security Misconfiguration	MIME Sniffing	Increased risk of MIME sniffing attacks	2	2	4
F07	Uncommon header ‘platform’	Information Leakage	Reconnaissance	Potential exposure of hosting platform info	1	1	1
F08	File Path Exposure via E-Tags	Information Leakage	Reconnaissance	Potential exposure of server file paths	1	2	2

F09	Strict-Transport-Security Header not defined	Security Misconfiguration	Man-in-the-Middle	Increased risk of MITM attacks	2	2	4
F10	alt-svc Header	Information Leakage	Reconnaissance	Potential exposure of server capabilities	1	1	1
F11	Unpresent CGI Directories	Lack of Function Level Access Control	Unauthorized Access	Potential for unauthorized access to CGI directories	1	1	1
F12	SSL Negotiation failure	Transport Layer Protection	Man-in-the-Middle	Increased risk of MITM attacks	2	2	2

In the summary tables above :

- Finding ID: Unique identifier for each finding.
- Issue: Describes the specific issue or vulnerability.
- Vulnerability: Classifies the type of vulnerability (e.g., Information Leakage, Authentication Weakness, Security Misconfiguration, etc.).
- Threat: Identifies the potential threat associated with the vulnerability.
- Consequence: Describes the potential consequence or impact if the vulnerability is exploited.
- Likelihood: Estimates the likelihood or probability of the vulnerability being exploited.
- Impact: Assesses the potential impact on the organization if the vulnerability is exploited.
- Risk Score: Combines likelihood and impact to provide an overall risk assessment.

IMPACT and Likelihood: **1 (LOW), 2 (MEDIUM) ,3(HIGH)**

Risk Score: 1-3 (Low) 3-4(Medium), 5-9(High)

Recommendations

Here Risks are prioritized based on the Risk Score, with higher scores indicating higher priority.

Utilize Web Application Firewalls (WAFs): Implement a WAF to provide an additional layer of protection against application-level vulnerabilities and to filter out potentially harmful requests.
Security Information and Event Management (SIEM): Implement SIEM solutions to monitor and analyze logs for suspicious activities, including potential exploitation attempts.
Security Training and Awareness: Provide training to development and operations teams on secure coding practices and server configuration to prevent similar issues in the future.

Provide clear and actionable recommendations for addressing the identified vulnerabilities and improving network security. These should be organized by priority.

Critical Recommendations:

Immediate actions to address critical vulnerabilities.

High-Priority Recommendations:

Remediation steps for high-risk findings.

Medium-Priority Recommendations:

Lower-priority issues that should still be addressed.

Low-Priority Recommendations:

Less critical issues that can be addressed over Time.

Conclusion

Summarize the key findings, risks, and recommendations. Highlight the importance of addressing the identified vulnerabilities.

Additionally, always ensure that you're making these changes in compliance with your organization's policies and best practices, and consider the potential impact on legitimate users and administrators.

Appendices

Include any supplementary information, such as detailed logs, additional evidence, or technical details that support the findings.

Acknowledgments

Thank the client for the opportunity to conduct the penetration test and acknowledge any cooperation or support received during the engagement.

Contact Information

Provide contact information for the penetration testing team or the report's author in case the client has questions or requires further clarification

#NOTE:

Limitations:

1. **Denial-of-Service (DoS) Attacks:** The engagement will not include testing for DoS attacks, as they have been explicitly excluded from the scope.
2. **Physical Security:** Physical security assessments, including on-site evaluations, will not be conducted as part of this engagement.